



HACKER WOMEN COUNCIL — ETHICAL HACKING

Actividad 01 - Análisis y planificación del pentest

Karen Itzel Jaime Castillo

Escenario: Aurora Market (🛒 Tu tienda. Tu confianza. Tu seguridad.)

🎯 1. OBJETIVO DEL PENTEST

- Evaluar la aplicación web de Aurora Market para adoptar la perspectiva de un atacante real mediante una simulación controlada, permitiendo descubrir vulnerabilidades críticas (como fallos de seguridad, problemas de autenticación, control de accesos rotos o validación deficiente de entradas) antes de que de que actores malintencionados puedan explotarlas.
 - Aportar un valor preventivo al proteger la confidencialidad de la información de identificación personal y financiera de miles de clientes, resguarda la reputación de la marca frente a posibles filtraciones de datos y garantiza que la infraestructura web opere con los estándares de seguridad adecuados para mantener la confianza del mercado.
 - Conocer el grado real de exposición de los activos digitales, validando si las defensas actuales son capaces de detectar, resistir o mitigar un intento de intrusión real. Para finalmente proponer directrices de mitigación y entregar recomendaciones claras y prácticas para que el equipo de desarrollo corrija los hallazgos y fortalezca la postura de seguridad general. Este pentest no responde meramente a un cumplimiento normativo o de checklist, sino a una necesidad de gestión de riesgos para proteger la plataforma.
-

📋 2. ALCANCE (SCOPE)

✓ SÍ SE EVALUARÁ (Sistemas o elementos incluidos):

- La plataforma web de comercio electrónico de Aurora Market (aplicación web autorizada).
- Los mecanismos de autenticación y control de usuarios.
- Paneles de administración de usuarios, productos y pedidos del personal interno.
- La base de datos y flujos de consulta de pedidos e información de clientes involucrados en la aplicación web.

✗ FUERA DEL ALCANCE (Elementos excluidos):

- Redes sociales de la empresa.
- Equipos personales, cuentas de correo o dispositivos de los empleados.
- Proveedores externos u otros sistemas tecnológicos que no formen parte de la

plataforma acordada.

- Pruebas de denegación de servicio (DoS/DDoS) que puedan interrumpir el negocio o afectar la información real de los clientes.

3. AUTORIZACIÓN Y CONDICIONES

- **Permisos requeridos:**

- Autorización formal por escrito firmada por la dirección de Aurora Market para realizar las pruebas de penetración.
- Carta de liberación de responsabilidad que delimite el marco legal del ejercicio ético.
- Credenciales de prueba (usuarios de distintos roles) proporcionadas por el cliente para evaluar la lógica de privilegios.

- **Condiciones acordadas:**

- Las pruebas se realizarán estrictamente sobre la aplicación web autorizada.
- Se ejecutarán en horarios de menor actividad para mitigar cualquier impacto operativo.
- Compromiso de confidencialidad absoluta sobre los datos de los clientes y hallazgos encontrados.
- Definir un Plan de Respuesta a Incidentes

-  **Propuesta de Horarios:** Las pruebas intrusivas y análisis activos se programarán estrictamente en horarios de menor afluencia de usuarios (ventanas de mantenimiento nocturnas, de 01:00 AM a 05:00 AM). Esta decisión se toma para salvaguardar la estabilidad operativa de la tienda en línea de Aurora Market. Al ejecutar análisis de vulnerabilidades en estas horas de baja carga, se mitiga el riesgo técnico de saturar los servidores, protegiendo la experiencia de los clientes.

4. TIPO DE PENTEST

Tipo de pentest elegido: Gray-box

 BLACK-BOX	 GRAY-BOX	WHITE-BOX
Sin conocimiento previo de la infraestructura o código.	El evaluador tiene información parcial, como credenciales o datos de la aplicación. Aurora Market entrega información parcial (credenciales, roles,	Acceso total a arquitectura y código fuente.

 BLACK-BOX	 GRAY-BOX	WHITE-BOX
	endpoints). Simula un atacante con ciertos accesos internos o visión semi-pública, optimizando tiempos.	

Justificación de la elección:

Aurora Market entrega información parcial al equipo de seguridad. Se sabe que existe una aplicación web, una base de datos y mecanismos de autenticación con distintos roles, pero no se conoce todo el código fuente ni los detalles profundos de la arquitectura de construcción. Esto simula de manera realista a un atacante con ciertos privilegios internos o información semi-pública, optimizando el tiempo de evaluación.

5. PLANIFICACIÓN

-  **Objetivos:** Definir el enfoque táctico hacia la identificación de brechas críticas en los flujos de autenticación, la validación de controles de acceso y la mitigación de fugas de datos de usuarios en la plataforma de Aurora Market.
-  **Alcance:** Delimitación estricta y formal al entorno web de comercio electrónico de Aurora Market, excluyendo de manera explícita redes sociales, infraestructura cloud de terceros y dispositivos personales de empleados.
-  **Permisos y condiciones:** Obtención formal de la carta de autorización (Rules of Engagement), entrega de credenciales de prueba con diversos roles y establecimiento de ventanas de mantenimiento nocturnas (01:00 AM a 05:00 AM) para mitigar riesgos de denegación de servicio (DoS) involuntaria.
-  **Metodología a utilizar:** Adopción de marcos de referencia internacionales especializados en seguridad web y pruebas de intrusión, tales como la Guía de Pruebas de OWASP (OWASP WSTG) y el estándar PTES.
-  **Recopilación de información previa:** Ejecución estructurada de fases de inteligencia (Footprinting), combinando reconocimiento pasivo (consultas Whois Lookup y motores de búsqueda OSINT para huella digital) y reconocimiento activo (mapeo de puertos abiertos y fingerprinting de servicios web mediante Nmap).
-  **Recursos necesarios:** Aprovisionamiento de un entorno de pruebas controlado, estaciones de trabajo con distribuciones especializadas (Kali Linux), suites de interceptación de tráfico (Burp Suite / OWASP ZAP) y escáneres autorizados.
-  **Programación del pentest:** Calendarización rigurosa de las fases de ejecución

(Reconocimiento → Análisis de Vulnerabilidades → Explotación → Post-explotación → Informe) respetando los horarios de baja afluencia acordados con la dirección de Aurora Market.

6. FASES DEL PENTEST

1. Reconocimiento:

En esta etapa inicial, abordaremos el escenario combinando fuentes abiertas y métodos activos para trazar la superficie de ataque:

-  **Recopilación Pasiva (OSINT / Whois):** Utilizaremos herramientas de consulta pública como *Whois Lookup* para examinar el registro del dominio de Aurora Market, identificar fechas de creación, organizadores y servidores DNS autoritativos, operando de manera silenciosa sin alertar al objetivo. Se complementará con técnicas de motores de búsqueda para detectar posibles subdominios expuestos o documentos indexados por error.
-  **Recopilación Activa (Escaneo de Puertos y Servicios):** Se empleará la herramienta *Nmap* para el escaneo de puertos y descubrimiento de servicios activos. Se ejecutará un análisis para identificar puertos abiertos (como el 80, 443 o servicios internos expuestos) y realizar un *fingerprinting* de los servicios detectados. Esto nos permitirá conocer con exactitud las versiones del servidor web y tecnologías subyacentes, identificando si existen componentes desactualizados o configuraciones predeterminadas antes de avanzar a la explotación.

2. Análisis de vulnerabilidades:

Herramienta principal: OWASP ZAP (y herramientas complementarias de interceptación como *Burp Suite*).

Una vez mapeados los puntos de entrada, utilizaremos OWASP ZAP para realizar un escaneo automatizado y análisis dinámico sobre la aplicación web de Aurora Market. Buscaremos detectar fallos comunes contemplados en el marco de *OWASP Top 10* (como inyecciones SQL en formularios de búsqueda, fallos de control de acceso horizontal/vertical o debilidades en la gestión de sesiones). Esto nos entregará un panorama claro de las debilidades lógicas y técnicas explotables en la plataforma.

Tales como:

1. *Broken Access Control (A01)*: Validación de que un usuario no pueda acceder a datos o paneles de otros clientes (IDOR).
2. *Security Misconfiguration (A02)*: Detección de configuraciones por defecto o cabeceras de seguridad faltantes.
3. *Injection (A05)*: Pruebas de validación en formularios de búsqueda y registro para descartar inyecciones SQL o XSS.

3.  **Explotación:** Validación controlada mediante pruebas para confirmar si las vulnerabilidades detectadas en OWASP ZAP son reales y permiten realizar acciones no autorizadas (ej. ver datos de otro usuario), perteneciente a otra cuenta, tal como reportó el usuario.
4.  **Post-explotación:** Evaluación del impacto máximo alcanzable con los accesos obtenidos, verificando si es posible la escalada de privilegios o la extracción simulada de información sensible, manteniendo la integridad operativa.
5.  **Informe:** Documentación detallada de cada hallazgo con su nivel de gravedad (CVSS), evidencias técnicas y rutas claras de remediación (*hardening*) para el equipo de desarrollo de Aurora Market.

7. INVESTIGACIÓN

METODOLOGÍA ELEGIDA:	¿POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?:
<i>OWASP Top 10 / OWASP Web Security Testing Guide (WSTG).</i>	<i>Porque está diseñada específicamente para aplicaciones web de comercio electrónico como Aurora Market. Proporciona un marco estandarizado y exhaustivo para evaluar los riesgos más críticos en la web (como control de accesos rotos, fallas criptográficas o inyecciones), asegurando que ninguna vulnerabilidad clave en la gestión de usuarios o datos personales quede sin revisar.</i>
<i>PTES - Penetration Testing Execution Standard</i>	<i>Complementa la evaluación al estructurar de manera profesional todo el ciclo de vida del pentest (desde la inteligencia inicial y el análisis de amenazas hasta la explotación y el reporte), asegurando que el proyecto se ejecute bajo un rigor metodológico de consultoría corporativa.</i>




Nombre completo: Karen Itzel Jaime Castillo

Fecha: 28/08/2026